



Interactive cross-walk: HECVAT vs 1EdTech TrustEd Apps rubrics — side-by-side coverage gaps across security, privacy, and accessibility

Computer
Procurement decision matrix: HECVAT Full/Lite vs 1EdTech TrustEd Apps certification — which framework fits your institution's vendor vetting workflow
Computer
Show me the complete crosswalk table
Export this framework as an Excel template
Draft an intake policy for campus edtech

HECVAT and 1EdTech TrustEd Apps overlap heavily on privacy, security, and accessibility, but they serve different purposes: **HECVAT is the deeper higher-ed vendor-risk assessment, while TrustEd Apps emphasizes education-specific transparency, learner data practices, accessibility, AI disclosure, and interoperability.** I also created a campus edtech vendor-intake policy template that turns this crosswalk into a repeatable review workflow.

Complete crosswalk table

Use this score scale in the workbook or compliance dashboard:

Score	Meaning				
0	Missing, unknown, unsafe, or contradicted by evidence				
1	Policy or design exists, but implementation/evidence is incomplete				
2	Implemented, but manual, partially tested, or inconsistently evidenced				
3	Implemented, owned, monitored, tested, and audit-evidenced				
4	Independently tested, automated where appropriate, continuously improved, and transparently reported				
Domain	HECVAT 4 coverage	1EdTech TrustEd Apps coverage	Overlap	Primary gap to close	Required Semester evidence

Score	Meaning				
---	---	---	---	---	---
Governance and accountability	Organization, policy governance, risk management, workforce controls	Company/policy information and responsible supplier practice	High	HECVAT typically requires more formal operational evidence	Governance charter, RACI, policy register, risk register, review minutes
Security program	Security policies, training, risk assessment, audits	Security procedures/processes and baseline practices	High	TrustEd is not a substitute for technical assurance	Training records, security program plan, control-testing schedule
Cloud infrastructure	Hosting, network, compute, storage, operations, monitoring	System management and third-party hosting disclosure	High	HECVAT usually probes architecture and operations more deeply	Architecture diagram, IaC, CSPM results, network/security configuration evidence
Identity and access	Authentication, MFA, authorization, privileged access, reviews, offboarding	Authentication and account-management practice	High	Need operating evidence, not statements	IAM design, MFA posture, RBAC matrix, quarterly access reviews, offboarding records
Secure development	SDLC, application security, change/release control, vulnerability management	Software development and maintenance practices	High	HECVAT generally asks for deeper testing/remediation evidence	Threat models, branch protections, CI scans, code-review samples, release approvals
Encryption and secrets	Encryption, key management, credential protection	Data protection/security practice	High	Need key lifecycle and implementation proof	TLS/KMS settings, secrets-vault policy, rotation evidence, access logs
Multi-tenant separation	Data segregation, authorization, infrastructure isolation	Hosting/data-separation and responsible data handling	High	Must demonstrate technical enforcement and test results	Tenant-isolation test suite, row-level authorization policy, penetration-test scope/results
Monitoring and logging	Security logging, alerting, monitoring, investigation support	Security monitoring/process disclosure	Medium-high	Define what is logged, who can access it, and retention	SIEM/log architecture, alert tests, audit-event samples, retention configuration
Vulnerability management	Scanning, patching, remediation, penetration testing	Security assessment/maintenance process	High	Evidence of severity SLA and remediation effectiveness	Scan reports, patch dashboard, pen-test summary, exception register
Incident response	Incident plan, notification, exercises, post-incident actions	Security incident process	High	HECVAT more often requires response-time and evidence detail	IR runbook, tabletop evidence, postmortem tracker, status templates
Business continuity	Backup, DR, availability, RTO/RPO	General operational security reliability	Medium	TrustEd does not replace a detailed recovery review	Restore-test results, DR plan, RTO/RPO evidence, vendor-outage playbook

Score	Meaning				
Data inventory	Classification, processing, data flows, privacy governance	Data collected, collection method, purpose, ownership	High	Link every UI field and integration to operational purpose/retention	Data inventory, data-flow diagrams, field-classification registry
Data ownership and control	Privacy, contractual use, access, data rights	Strong emphasis on learner/customer ownership, collection, and use	High	Clarify contract roles and technical user controls	DPA, privacy policy, export/delete/share-revoke workflows
Retention, deletion, legal hold	Lifecycle, disposal, backup handling, compliance	Retention and deletion rights/policy transparency	High	Operational deletion across caches, indexes, backups, and hold cases	Retention schedule, deletion test, legal-hold runbook, backup-expiry evidence
Data sharing/subprocessors	Vendor risk, third parties, transfers, contracts	Hosting/sharing disclosure and transparency	High	Need onward-transfer, residency, and exit evidence	Public subprocessor list, vendor reviews, DPAs, exit/offboarding plan
FERPA and education records	Privacy/legal safeguards and contracts	Education-data ownership/transparency	Medium-high	Institution-specific school-official/consent/legal analysis	FERPA workflow, consent ledger, disclosure log, access matrix
Accessibility	IT accessibility, conformance, alternatives	Accessibility documentation, procurement communication, conformance, accommodations	High	Test every role and workflow—not only the public site	Current ACR/VPAT, manual test evidence, issue tracker, release gate
Interoperability	API/integration security and data transfer	LTI, OneRoster, QTI, CLR/Open Badges, certifications/conformance	Medium	HECVAT does not prove education-standard conformance	LTI/OneRoster/QTI test logs, API docs, sandbox, data maps
Community and social safety	Privacy, user-generated content, incident handling	Social-interaction transparency/data practice	Medium-high	Add moderation, harassment, escalation, appeal, and retention controls	Community policy, moderation runbooks, training, case audit evidence
AI disclosure	AI governance, data/vendor/change controls	AI use notice, purpose, source, provider/internal-vs-third-party disclosure	High	Ensure UI transparency and policy match actual model behavior	AI policy, product screenshots, model/provider inventory
AI data use/training	AI data flow, vendors, privacy/security controls	Training/retention/ownership transparency and user choice	High	Technically enforce no-training default and deletion propagation	Provider terms, gateway config, AI data-flow diagram, deletion tests
AI quality and misuse	AI risk, security, evaluation, operations	Broad transparency and data-practice expectations	Medium	Add NIST AI RMF/AI 800-1 evaluations, red teaming, kill switch	Risk register, evaluation reports, red-team evidence, AI incident runbook
Assessment and grade integrity	Product integrity, privacy, audit, availability	Responsible learner-data/AI disclosure	Medium	Add educational validity, human judgment, rubric provenance, appeal	Grade ledger, rubric versioning, grading review logs, appeal workflow

Score	Meaning				
Customer assurance	Questionnaire completion, contracts, evidence sharing	Public transparency, Trusted Apps directory/certification path	Medium-high	Keep evidence fresh and customer-specific	HECVAT answer library, Trust Center, evidence-vault index, customer trust dashboard

TrustEd Apps security materials are designed as a baseline review of supplier policies, procedures, and processes, including areas such as software maintenance, authentication, service management, and cloud infrastructure; HECVAT is generally the more detailed operational questionnaire for institutional vendor review. ^[1]

Procurement-fit matrix

Situation	HECVAT Full	HECVAT Lite	1EdTech TrustEd Apps	Recommended decision
Public informational tool; no login or personal data	Usually unnecessary	Possible if local policy requires	Public privacy/accessibility review	Lightweight review and accessibility check
Departmental instructional tool with SSO and limited student data	May be excessive initially	Appropriate starting point	Request privacy/security/accessibility self-assessment if available	Moderate review plus data-flow and DPA review
LMS, assessment, student-success, advising, community, or AI tool	Usually appropriate	Use only if institution's risk process allows	Strongly recommended, especially privacy/accessibility/AI/interoperability evidence	High-risk review with HECVAT, TrustEd materials, ACR/VPAT, integration test
SIS, gradebook, payment, proctoring, health/basic-needs intake, or broad production-data export	Required or strongly expected	Insufficient alone	Useful complement, but not sufficient	Full HECVAT, technical security review, DPIA/PIA, legal review, executive approval
Vendor claiming 1EdTech certification	Still useful for security/procurement depth	May supplement initial triage	Verify exact certification and scope	Do not treat certification as a substitute for HECVAT
AI-enabled tool with education-record data	Appropriate based on data/use risk	Only for a constrained low-risk pilot	Request Gen-AI Data Rubric materials	Add AI impact assessment, provider review, model evaluation, and contractual AI controls

Vendor intake workflow

```

Business request
→ risk classification
→ required-artifact request
→ secure evidence submission
→ HECVAT + TrustEd + AI crosswalk
→ security/privacy/accessibility/AI/integration review
→ findings and required contract terms
→ approval / conditional approval / pilot only / defer / reject

```

- implementation launch gates
- annual and change-triggered reassessment

Risk tiers

Tier	Trigger	Review scope
Low	No institutional personal data, no account, no integration, no AI	Privacy, legal, accessibility baseline
Moderate	Limited directory data, SSO, low-risk learning/service use	Data flow, privacy, security, accessibility, contract review
High	Education records, LTI/SIS/SCIM, AI, assessments, community, student-generated content	HECVAT, TrustEd evidence, ACR/VPAT, integration review, DPA, AI review
Critical	Payments, proctoring, minors, health/basic-needs intake, agentic writes, high-stakes data/export	Full HECVAT, DPIA/PIA, threat model, legal and executive approval, strict launch gates

Required approval states

Approved
 Approved with conditions
 Pilot only
 Deferred
 Not approved

A vendor should never be marked “approved” merely because it provided a completed questionnaire. Approval requires an institution-specific conclusion about evidence, residual risk, contractual terms, configuration, and the proposed use case.

AI governance overlay

Control area	HECVAT-oriented expectation	TrustEd Apps-oriented expectation	Semester control
Inventory	Identify AI features, providers, integrations, data and affected users	Disclose AI use and purpose	AI system inventory by feature, tenant, model/version, owner, risk tier
Transparency	Explain limitations and customer impact	Identify AI use, source, internal vs third-party provider	Source/Scope/Status labels, model/provider notice, issue-report route
Data flow	Classify inputs, outputs, retrieval, logs, provider processing	Explain data sources and handling	Tenant-scoped retrieval, AI data-flow diagram, no cross-tenant retrieval
Training	Govern provider retention/training and secondary use	Disclose training/data-use practice and user choices	No general-purpose training on production student/customer data by default
Human control	Prohibit/limit consequential automation	Responsible, transparent use	No AI-only final grades, misconduct decisions, aid, discipline, admissions, or accommodation decisions
Evaluation	Test quality, bias, privacy, security, accessibility	Consider validity/bias and data practice	Grounding, hallucination, safety, prompt-injection, accessibility and fairness evaluations
Misuse	Threat-model tool abuse, exfiltration, impersonation, harmful output	Disclose provider/data behavior	Least-privilege tools, rate limits, filters, human review, kill switch
Incident response	AI incident triage, notification, remediation	User transparency and recourse	AI-specific severity model, report/appeal path, rollback and corrective actions

Control area	HECVAT-oriented expectation	TrustEd Apps-oriented expectation	Semester control
Change management	Review model/provider/prompt/tool changes	Update disclosure after material change	Risk reassessment, re-evaluation, evidence refresh, customer notice where needed
Retention	Define prompt/output/log lifecycle	Disclose data handling	Separate retention classes for prompts, outputs, retrieval caches, and evaluation samples

1EdTech’s Generative AI Data Rubric is specifically intended as a supplier self-assessment focused on transparency and user options, including disclosure of AI usage, data sources, and whether AI is internal or supplied by a third party. ^{[1692][1693]}

Campus intake policy

I created the **Campus EdTech Vendor Intake Policy** as a downloadable Markdown document. It includes:

- Scope, principles, roles, and decision rights.
- Low/moderate/high/critical risk tiers.
- Evidence requirements for standard, high-risk, and AI-enabled vendors.
- Cross-functional review and approval flow.
- Contractual and configuration requirements.
- Production launch gates.
- Annual, renewal, incident, and material-change reassessment.
- Time-bound exception governance.

The policy document is available in the file panel.



1. <https://www.educause.edu/higher-education-community-vendor-assessment-toolkit/hecvat-faqs-for-corporations>
2. <https://www.1edtech.org/blog/setting-expectations-on-security-practices>
3. https://www.1edtech.org/sites/default/files/media/docs/2024/WBR_Rubrics_032724.pdf
4. https://www.1edtech.org/sites/default/files/media/docs/2023/Data-Privacy_AI-Rubric.pdf